Защита информации

Учебный проект реализует технические меры защиты, но не является автоматически сертифицированной системой и не подтверждает окончательное соответствие 152-ФЗ, 149-ФЗ или приказу ФСТЭК №117. Применимость требований, категория системы, модель угроз и полнота мер определяются заказчиком с профильными специалистами. Ниже описаны фактические свойства реализации и границы ответственности.

Реализовано

- Keycloak OIDC Authorization Code + PKCE S256; backend проверяет RS256, подпись, issuer, audience, exp, iat и sub. Direct password grant frontend отключён. Access token хранится только в памяти SPA.

- RBAC и серверная область доступа к ВУЗам/взаимодействиям. Проверяются отчёты, импорт, комментарии, файлы и интеграции. Роль и блокировка сотрудника читаются в БД без Redis, поэтому изменения применяются к следующему запросу.

- Валидация Pydantic, ограничения внешних ключей и уникальности; параметризованные ORM-запросы; optimistic concurrency.

- Файлы вне БД, случайные имена, проверка расширения/MIME/сигнатур/размера, защита от path traversal. Для Office ZIP проверяется структура и суммарный размер распаковки. Содержимое не исполняется, защищённая выдача — как attachment. Антивирусная проверка не реализована.

- Аудит before/after критичных операций. Нет API удаления аудита. Параметры входа и токены не записываются в бизнес-аудит. Аудит может содержать персональные данные изменяемых объектов и требует собственной политики хранения.

- CORS allowlist, X-Content-Type-Options, X-Frame-Options, Referrer-Policy, Permissions-Policy; HSTS для HTTPS backend. Excel-формулы экранируются при экспорте. HTML в PDF экранируется.

- HTTPS/allowlist/no redirects для внешних API. Секреты внешних систем — только env. PostgreSQL и Redis внутри Compose-сети. Приложение backend работает непривилегированным пользователем.

До промышленной эксплуатации

Сменить все опубликованные демонстрационные пароли и bootstrap-данные. Удалить демопользователей/фикстуры, отключить SEED_DEMO. Перевести Keycloak из start-dev в production, задать TLS, точные внешние адреса, redirect URI и CORS без wildcard доменов. Ограничить сетевой доступ, отключить публичные служебные порты, защитить БД отдельными учётными записями и секрет-хранилищем.

Заказчик обеспечивает правовые основания и цели обработки, минимизацию и сроки хранения ПДн, локальные акты, матрицу допуска, обучение сотрудников, резервное копирование с проверкой восстановления, шифрование носителей/каналов по своей модели угроз, управление ключами, мониторинг, реагирование на инциденты и актуализацию компонентов. Нужны внешний rate limiting/WAF, защита секретов, антивирус файлов, контроль уязвимостей и регулярное тестирование доступа. Изоляция и неизменяемость аудита на уровне инфраструктуры требуют отдельного решения; администратор БД технически способен изменить записи.

Демонстрационный Compose публикует HTTP localhost и использует общую БД с отдельной схемой Keycloak. Это упрощение учебного стенда. Производственная схема должна разделять роли БД и доверенные зоны. Итоговая оценка соответствия проводится после выбора инфраструктуры и организационных мер, а не на основании наличия Dockerfile или JWT.